

Vulnerability Assessment Report

Project Title: Vulnerability Assessment Report

Target Website: <http://demo.testfire.net>

Submitted By: Prarthana A

Internship Domain: Cyber Security

Organization: Future Interns

Date: 13/05/2026

1.Objective

This report presents the results of a security assessment conducted on the target web application. The objective of this assessment was to identify publicly visible security weaknesses that could impact application security, user data, and overall system integrity. The testing was performed using passive and non-destructive techniques.

2. Scope

Target Website: <http://demo.testfire.net>

Testing Type: Black-box testing

Assessment Scope:

- Web application vulnerability assessment
- Security misconfiguration identification
- Open service analysis
- Security header inspection

The assessment was limited to publicly accessible pages and did not include exploitation or destructive testing.

3. Tools Used

3.1 OWASP ZAP

OWASP ZAP was used to identify common web application vulnerabilities including missing security headers, SQL Injection risks, Cross Site Scripting vulnerabilities, and cookie-related security issues.

3.2 Nmap

Nmap was used for network reconnaissance and identifying exposed ports and running services on the target system.

3.3 Browser Developer Tools

Browser Developer Tools were used to inspect HTTP headers, webpage elements, and cookie configurations.

3.4 Canva / Microsoft Word

Canva and Microsoft Word were used for preparing and formatting the professional vulnerability assessment report.

4. Skills Gained

- Web application vulnerability assessment
- Risk classification and analysis
- Usage of OWASP ZAP
- Network scanning using Nmap
- Security documentation and reporting
- Understanding of web security concepts

5. Methodology

1. Installed and configured Nmap and OWASP ZAP tools.
2. Performed network reconnaissance and port scanning using Nmap.

3. Conducted automated vulnerability scanning using OWASP ZAP.
4. Collected identified vulnerabilities and categorized them based on severity.
5. Analyzed findings and documented remediation recommendations.
6. Prepared the final professional assessment report.

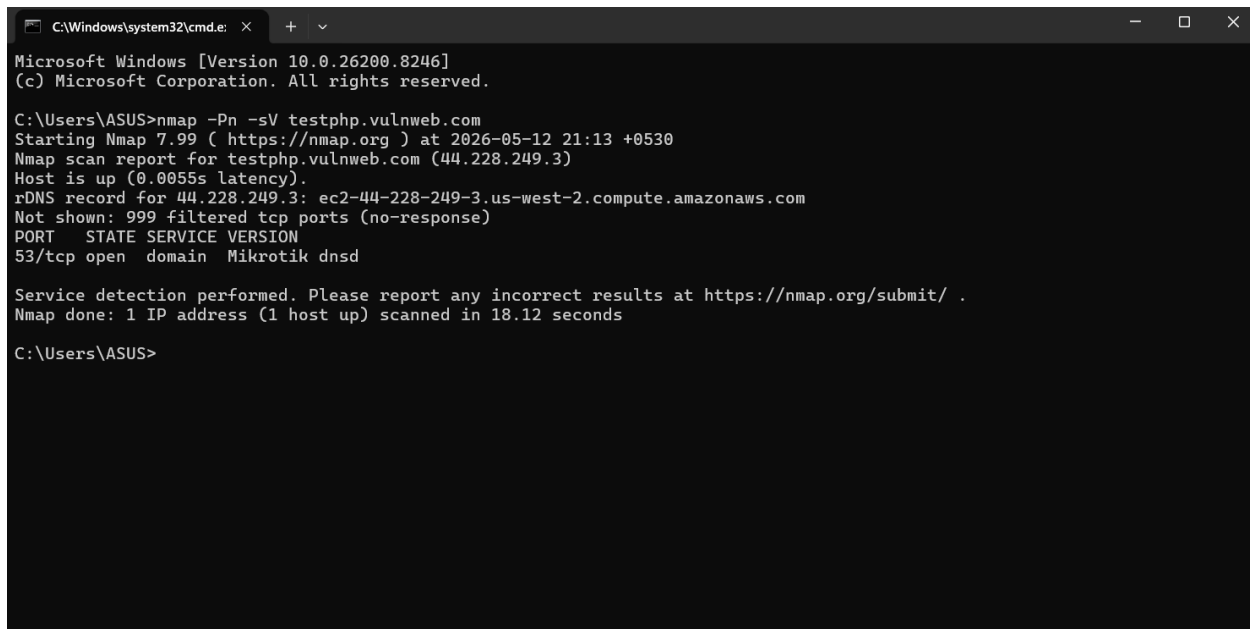
6. Nmap Scan Results

Command Used: `nmap -Pn -sV testphp.vulnweb.com`

Observation: The scan identified an exposed DNS-related service running on port 53. Exposed services may provide useful information to attackers if not properly secured.

Risk Level: Low

Recommendation: Restrict unnecessary exposed services and implement proper firewall configurations to reduce exposure.

A screenshot of a Windows command prompt window. The title bar shows the path 'C:\Windows\system32\cmd.exe'. The command prompt displays the output of the command 'nmap -Pn -sV testphp.vulnweb.com'. The output includes the Nmap version (7.99), the target IP (44.228.249.3), and the results of the scan, which shows a single open port (53/tcp) running a Mikrotik dnssd service. The prompt ends with 'C:\Users\ASUS>'.

```
C:\Windows\system32\cmd.exe
Microsoft Windows [Version 10.0.26200.8246]
(c) Microsoft Corporation. All rights reserved.

C:\Users\ASUS>nmap -Pn -sV testphp.vulnweb.com
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-12 21:13 +0530
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.0055s latency).
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain  Mikrotik dnssd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.12 seconds

C:\Users\ASUS>
```

Figure 1: Nmap Scan Result

7. OWASP ZAP Findings

Vulnerability	Risk Level
Cross Site Scripting (XSS)	High
SQL Injection	High
Missing Content Security Policy Header	Medium
Missing Anti-Clickjacking Header	Medium
Cookie Without SameSite Attribute	Medium
Server Information Disclosure	Low

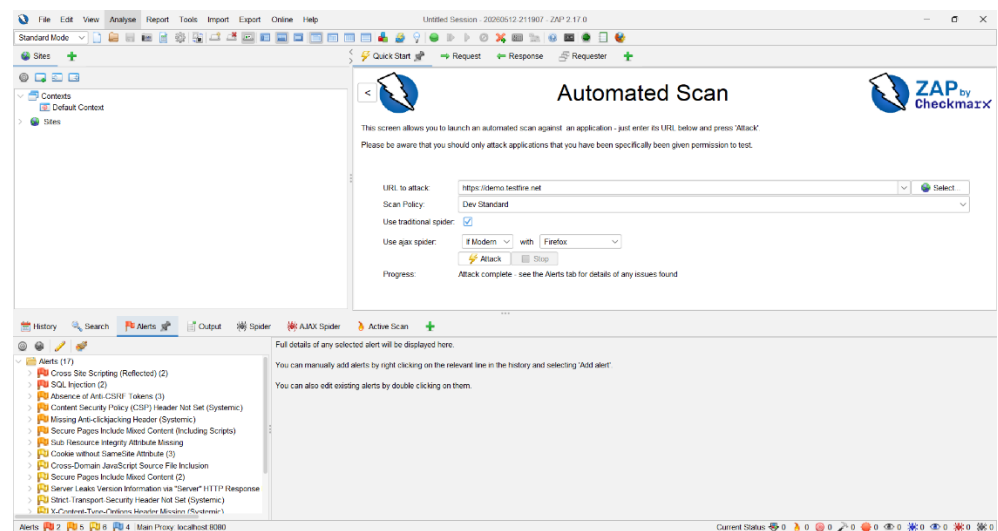
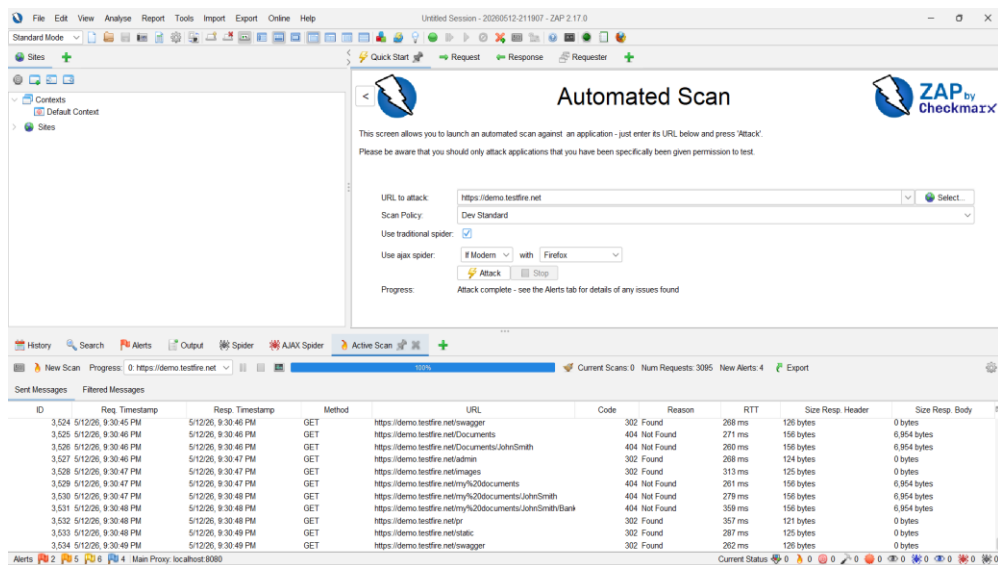


Figure 2: OWASP ZAP Result

8. Detailed Findings

8.1 Cross Site Scripting (XSS)

Risk Level: High

Description: Cross Site Scripting vulnerabilities may allow attackers to inject malicious scripts into webpages viewed by users. This can lead to session theft, phishing attacks, or unauthorized actions.

Recommendation: Validate and sanitize all user inputs properly before processing or displaying them within the application.

8.2 SQL Injection

Risk Level: High

Description: SQL Injection vulnerabilities may allow attackers to manipulate backend database queries through unsanitized user input fields.

Recommendation: Use parameterized queries, prepared statements, and proper input validation techniques to prevent SQL Injection attacks.

8.3 Missing Content Security Policy Header

Risk Level: Medium

Description: The absence of a Content Security Policy (CSP) header increases the risk of malicious script execution and content injection attacks.

Recommendation: Implement appropriate Content Security Policy headers to control the sources of executable scripts and resources.

9. Conclusion

The vulnerability assessment identified several security weaknesses within the target web application, including high-risk vulnerabilities such as SQL Injection and Cross Site Scripting. Proper security configurations, secure coding practices, and input validation mechanisms can significantly improve the overall security posture of the application. Regular security assessments and timely remediation are recommended to maintain application security.